Heritage Bank Digital — Compliance & Risk Reference

Document type: Compliance / Risk Reference
Version: 3.2
Owner: Heritage Bank Compliance, Risk & Information Security

---

1. Bank Secrecy Act (BSA) / Anti-Money Laundering (AML)

1.1 Programme Overview

Heritage Bank maintains a BSA/AML programme compliant with 31 U.S.C. § 5318. NICE Actimize is the transaction monitoring engine; the Fraud & Compliance Service consumes Actimize alerts via Kafka and manages the case workflow.

1.2 Customer Identification Programme (CIP)

Rule: Before opening any account, Heritage must verify the identity of each customer.

Required information (31 CFR 1020.220):

- Legal name, date of birth (individuals), address, TIN / SSN / EIN
- Government-issued photo ID (driver's licence, passport) — scanned and stored in Customer Service document vault
- For business accounts: EIN, articles of incorporation, beneficial ownership certification (FinCEN 107 equivalent)

Verification method: Okta Identity + Experian identity verification API (knowledge-based authentication or document verification). Result stored as `CIP_VERIFIED` or `CIP_MANUAL_REVIEW` on the Customer record.

Implementation requirement: No account may be opened and no transaction permitted until CIP status = `CIP_VERIFIED`. Manual review queue for `CIP_MANUAL_REVIEW` — branch manager or compliance officer must act within 2 business days.

1.3 Transaction Monitoring

- NICE Actimize receives real-time transaction feed from Payment Service via Kafka topic `transaction.posted`
- Actimize evaluates rules (velocity, structuring, geographic, counterparty risk) and emits alerts back via REST to Fraud & Compliance Service
- Fraud & Compliance Service creates cases; Compliance Officer assigned via round-robin

1.4 Currency Transaction Reports (CTR)

Rule: File FinCEN Form 104 within **15 calendar days** of any cash transaction (or series of related transactions) totalling ≥ $10,000 in a single business day by or for any person.

Implementation:

- Branch Teller App records cash transaction amounts in real time to Compliance Service
- Compliance Service aggregates per-customer daily cash totals; triggers CTR workflow when $10,000 threshold met
- Reporting Service generates and submits CTR to FinCEN BSA E-Filing portal; confirmation ID stored
- Branch manager review required before submission

1.5 Suspicious Activity Reports (SAR)

Rule: File FinCEN Form 111 within **30 calendar days** of determining that a transaction involves ≥ $5,000 and may involve money laundering, structuring, or fraud. Extension to 60 days allowed with documentation.

Workflow:

1. Actimize flags case → Compliance Officer reviews
2. Determination made: SAR required / not required (documented either way)
3. If required: Compliance Officer completes SAR narrative; Compliance Manager approves
4. Reporting Service submits to FinCEN BSA E-Filing within 30 days of determination
5. BSA records (including negative decisions) retained **5 years**

1.6 Record Retention

Record type	Retention
CIP documents	5 years after account closure
CTR filings	5 years from filing date
SAR filings (and negative determinations)	5 years from filing date
Transaction records	5 years
Audit logs (BSA-related)	5 years

---

2. Regulation E — Electronic Fund Transfers

2.1 Error Resolution (12 CFR Part 1005)

When a customer reports an unauthorised or erroneous EFT:

Step	Requirement	System
Acknowledge dispute	Within 10 business days	Notification Service sends confirmation email
Provisional credit	Within 10 business days of notice	Account Service → BIH posts provisional credit
Investigation	Within 45 business days	Compliance team works Salesforce case
Written resolution	Within 3 business days of completion	Notification Service sends email; letter generated
Permanent resolution	Debit or credit per investigation outcome	Account Service → BIH posts final entry

Implementation requirements:

- Dispute form must capture: transaction date, amount, merchant, description of the error
- Provisional credit must appear as a distinct line item in transaction history with label "Dispute — provisional credit (pending)"

- Resolution clock (10 BD / 45 BD) must be tracked by Fraud & Compliance Service; P2 alert to compliance team if deadline approaching

2.2 Error Codes

Payment Service must translate ACH NACHA return codes to plain English before displaying to customers. Examples:

NACHA code	Customer-facing message
R01	Payment returned: insufficient funds at receiving bank
R02	Payment returned: account closed at receiving bank
R03	Payment returned: account number does not exist
R16	Payment returned: account frozen
R29	Payment returned: not authorised by receiving bank

---

3. Regulation D — Savings and Money Market Accounts

Rule: Federal Regulation D historically limited "convenient" withdrawals from savings and money market accounts to **6 per statement cycle**. Although the Federal Reserve removed this limit in 2020, Heritage Bank **continues to enforce a 6-withdrawal limit** per its retail deposit agreement (competitive positioning as a traditional bank).

Enforcement at Payment Service:

- Transfer from savings/money market counts toward the 6-withdrawal limit
- On the 7th+ withdrawal: $10 fee applied; customer notified via push/email at the time of transaction
- If limit exceeded in 3 consecutive statement cycles: Account Service flags account for conversion to checking; written notice sent (5-day advance)

Implementation:

- Payment Service checks withdrawal count via Account Service before posting any savings debit
- Count incremented atomically using a Redis counter (keyed by account + statement cycle)
- Counter reset at statement cycle boundary (triggered by AS/400 EOD batch event on Kafka)

---

4. Sarbanes-Oxley (SOX) — IT General Controls

4.1 Change Management (ITGC CC6.8 / CC8.1)

All production changes to Heritage Digital systems require:

1. **Change ticket** in ServiceNow with: description, risk assessment, test evidence, rollback plan
2. **CAB (Change Advisory Board) approval** — meets Tuesday and Thursday; emergency CAB available 24/7
3. **Segregation of duties**: developer who writes the code may not be the one who promotes to production
4. **Post-implementation review**: within 5 business days; evidence stored in ServiceNow

No developer has production access — enforced by AWS IAM policy (deny all except dedicated DeployRole assumed by the CI/CD pipeline after CAB-approved token generation).

AS/400 changes: prohibited for Heritage Digital team. Any AS/400 change must go through FiServ Precision change process (separate team, 4-week lead time minimum).

4.2 Deployment Freeze Periods

- **No production deployments** on Fridays after 15:00 CT (risk of weekend outage with reduced support)
- **No production deployments** on US public holidays or Heritage Bank observed holidays
- **Quarterly close freeze**: last 2 business days of each fiscal quarter — no non-emergency changes
- Emergency exception: requires CISO + CTO written approval via ServiceNow

4.3 Audit Evidence Requirements

The following must be captured and retained for **7 years** for SOX audit:

- All deployment pipeline runs (GitHub Actions logs archived to S3)
- CAB approval records (ServiceNow export)
- Access provisioning and de-provisioning events (Okta logs)
- All configuration changes to API Gateway, Lambda functions, and BIH routing rules
- Database schema migration scripts and execution evidence

---

5. PCI DSS — Cardholder Data Environment

Heritage Bank is **SAQ-D** (Service Provider) due to the network-level presence of card data via FIS Worldpay integration.

5.1 Card Data Flow

```
Customer device → FIS Worldpay (PAN capture + 3DS) → Network Token → Heritage Card
Management Service
```

- No PAN (Primary Account Number) is stored in Heritage Digital systems
- Card Management Service stores Worldpay-issued **token** + last 4 digits + expiry month/year + card art (brand)
- Worldpay handles authorisation, settlement, and dispute processing
- Heritage is out of scope for cardholder data storage but **in scope** for transmission (card token + transaction ID flow through Payment Service)

5.2 Requirements

- TLS 1.3 enforced on all Payment Service endpoints and BIH connections to AS/400
- Quarterly ASV scan of external perimeter
- Annual ROC (Report on Compliance) assessment by QSA
- Penetration test: annual; network segmentation test every 6 months
- FIS Worldpay DPA and BAA equivalent maintained; reviewed annually

---

6. Accessibility — ADA / Section 508

6.1 Standards

Channel	Standard

Mobile app	WCAG 2.1 AA; VoiceOver + TalkBack
Online banking	WCAG 2.1 AA; JAWS + NVDA + VoiceOver
Branch Teller App	Internal; keyboard navigable; WCAG 2.1 AA best effort
ATM (not in scope)	Regulated separately by ADA Standards for Accessible Design

6.2 Specific Requirements for Banking Context

- **Session expiry warnings**: must be announced via ARIA live region; customer given 60 seconds to extend before automatic logout
- **OTP / MFA entry**: digit fields must be individually accessible; paste from clipboard supported
- **Transaction confirmation**: all amounts and account numbers read by screen reader must include currency label ("five hundred dollars", not "500")
- **Error messages**: must appear adjacent to the field in error; colour contrast ≥ 4.5:1; not conveyed by colour alone

---

7. Risk Register — Digital Programme

Risk	Likelihood	Impact	Mitigation
AS/400 batch window causes customer-facing downtime	High	Medium	BIH queues all operations; UI shows maintenance message
BIH becomes a single point of failure	Medium	Critical	BIH deployed active-active across on-prem DC and AWS; IBM MQ persistent queues survive BIH restart
NICE Actimize Kafka consumer lag → delayed fraud alerts	Medium	High	Consumer lag monitoring with 30-second alert; dead-letter queue for dropped events
Screen-scraping still in use for legacy teller flows	High	Medium	BIH migration backlog tracked; green-screen dependency removed per service when BIH covers the operation
SOX change freeze blocks critical security patch	Low	High	Emergency change process documented and rehearsed; CISO empowered to approve same-day
Reg E provisional credit not posted within 10 BD	Low	High	Compliance Service tracks deadline; P1 escalation at day 8 if not resolved